CRISC Domain A - 100 Impossible Hard Questions

Governance - Expert Level That Will Break You

CRISC Mastery Series

October 21, 2026

Warning

Extreme Difficulty

These questions test the deepest governance judgment.
Every option will look plausible.
You must think like a board advisor, not a technician.

Outline

1. Organizational Governance
2. Legal, Regulatory and Ethical Requirements
3. Roles and Responsibilities
4. Enterprise Risk Management
5. Risk Culture
6. Third-Party Governance
7. Risk Appetite, Tolerance and Reporting
8. Business Continuity Governance
9. IT Resource and Performance Governance
10. Advanced Governance Scenarios

Q1: Governance vs Management

Question

The board sets a policy requiring security review for all new vendors. The CIO writes the procedures and assigns reviewers. Who is performing governance and who is performing management?

A. Both are governance
B. Both are management
C. Board performs governance; CIO performs management
D. Board performs management; CIO performs governance

Q1: Explanation

Correct Answer: C

Governance vs Management:

- Governance sets direction and accountability
- Management executes within that direction
- Board policy is governance
- CIO procedures are management

Critical Trap

Governance directs; management executes.

Q2: Accountability Trap

Question

The CISO delegates incident response to the SOC manager. The SOC manager mishandles a breach. Who is accountable to the board?

A. The SOC analyst who missed the alert
B. The SOC manager
C. The CISO
D. The vendor who sold the SIEM

Q2: Explanation

Correct Answer: C

Accountability does not delegate:

- Delegation transfers tasks, not accountability
- The CISO remains accountable for the security program
- The SOC manager is responsible for operations
- Accountability flows upward

Critical Trap

Accountability does not delegate with the task.

Q3: Policy vs Standard

Question

A statement says "all customer data must be encrypted." A second document says "AES-256 with FIPS 140-2 modules." Which is the policy and which is the standard?

A. Both are policies
B. Both are standards
C. The first is the policy; the second is the standard
D. The first is the standard; the second is the policy

Q3: Explanation

Correct Answer: C

Policy vs Standard:

- Policy states intent at a high level
- Standards are mandatory, specific requirements
- The encryption requirement is policy
- The algorithm specification is standard

Critical Trap

Policy states intent; standards specify requirements.

Q4: Tone at the Top

Question

Senior executives publicly commit to risk management but cut the security budget each year. What does this signal to the organization?

A. Strong risk culture
B. The culture will mirror actions, not words
C. Budget cuts are always appropriate
D. The board should relax oversight

Q4: Explanation

Correct Answer: B

Actions shape culture:

- Actions shape culture more than statements
- Employees observe what leaders do
- Inconsistent messages erode trust

Critical Trap

Actions speak louder than commitments.

Q5: Risk Appetite Authority

Question

The risk manager proposes the risk appetite. Who approves it?

A. The risk manager
B. The audit committee alone
C. The board of directors
D. The IT steering committee

Q5: Explanation

Correct Answer: C

Appetite is board-owned:

- Appetite is a board-level decision
- It reflects strategy and stakeholder interests
- Management proposes; the board approves

Critical Trap

Appetite is board-owned.

Q6: Three Lines - First

Question

Which function is the FIRST line of defense?

- A Risk management function
- B Internal audit
- C Business operations
- D External audit

Q6: Explanation

Correct Answer: C

First line = business operations:

- The first line owns and manages risk
- The second line oversees and advises
- The third line provides independent assurance

Critical Trap

The first line owns risk.

Q7: Three Lines - Second

Question

Who is the SECOND line of defense?

A. Operational managers
B. External auditors
C. A risk and compliance function that oversees first-line activities
D. The board

Q7: Explanation

Correct Answer: C

Second line oversees:

- The second line oversees risk practices
- It advises and challenges the first line
- The third line provides independent assurance

Critical Trap

Second line oversees, third line audits.

Q8: Three Lines - Third

Question

What is the MAIN purpose of the third line of defense?

A. Operating controls
B. Setting risk appetite
C. Independent assurance over the first and second lines
D. Approving risk responses

Q8: Explanation

Correct Answer: C

Third line = independent assurance:

- Third line is independent assurance
- It does not own risk
- It evaluates effectiveness

Critical Trap

Third line provides independent assurance.

Q9: Board Oversight

Question

A material IT risk exceeds appetite and is not being treated. What is the board's BEST action?

A. Implement the control directly

B. Direct management to treat or formally accept the risk with documentation

C. Ignore it

D. Delegate to the vendor

Q9: Explanation

Correct Answer: B

Boards direct; management executes:

- Boards direct management
- They do not implement controls
- Formal treatment or acceptance is required

Critical Trap

Boards direct; management executes.

Q10: Risk Committee

Question

An IT risk committee meets quarterly but decisions never reach the board. What is the MAIN governance gap?

A. Too many meetings
B. Insufficient reporting escalation to the board
C. Too many committee members
D. Not enough coffee

Q10: Explanation

Correct Answer: B

Escalation gap:

- Decisions must reach the accountable body
- Escalation keeps governance connected
- Committee work without board visibility is ineffective

Critical Trap

Without escalation, governance is disconnected.

Q11: RACI Accountable

Question

In a RACI chart, who is the single accountable party for an activity?

A. Everyone in the "R" column
B. The "A" - one accountable person
C. The "C" - consulted party
D. The "I" - informed party

Q11: Explanation

Correct Answer: B

One accountable per activity:

- "A" is single-point accountability
- "R" does the work
- "C" advises; "I" is informed

Critical Trap

One accountable, one "A".

Q12: RACI Consulted

Question

When an architecture team is marked "Consulted" on a risk initiative, what does that mean?

- A They perform the work
- B They approve the decision
- C They provide subject matter expertise before decisions
- D They receive updates only

Q12: Explanation

Correct Answer: C

Consulted = advice:

- Consulted parties give input
- Responsible parties do the work
- Accountable parties own decisions

Critical Trap

Consulted means advice, not decision.

Q13: Enterprise Risk Committee

Question

The enterprise risk committee includes only IT leaders. What is the MOST likely weakness?

A. Too many technology voices, not enough business representation
B. Too many business voices
C. Too few vendors
D. Too many meetings

Q13: Explanation

Correct Answer: A

Cross-functional needed:

- Enterprise risk requires cross-functional input
- IT alone cannot represent business risk
- Business, legal, finance, and operations should be included

Critical Trap

Enterprise risk needs cross-functional voices.

Q14: Governance of AI

Question

The organization adopts an AI tool without a defined owner or accountability. What governance principle is violated?

A. Segregation of duties
B. Accountability must be assigned
C. Least privilege
D. Defense in depth

Q14: Explanation

Correct Answer: B

Accountability required:

- Every initiative needs an accountable owner
- Unowned technology creates unmanaged risk
- Governance requires explicit accountability

Critical Trap

No owner means no governance.

Q15: Policy Exceptions

Question

An executive grants a policy exception verbally to a peer. What is the governance flaw?

A. No flaw, verbal is fine
B. Exceptions must be documented, approved by the appropriate authority, and reviewed
C. Exceptions should be free
D. Policy is optional

Q15: Explanation

Correct Answer: B

Exceptions need documentation:

- Exceptions need documentation
- Approval authority must be defined
- Review ensures validity

Critical Trap

Verbal exceptions are ungovernable.

Q16: Regulatory Prioritization

Question

The organization operates in multiple jurisdictions with conflicting privacy laws. What should the risk practitioner recommend?

A. Follow one jurisdiction only

B. Identify the intersection of obligations and design controls that meet the strictest applicable requirements

C. Ignore the conflict

D. Choose based on cost

Q16: Explanation

Correct Answer: B

Compliance is a floor:

- Conflicting laws require a control floor
- The strictest requirement sets the baseline
- Legal review confirms applicability

Critical Trap

Compliance is a floor, not a menu.

Q17: Ethics Beyond Law

Question

An activity is legal but violates the ISACA Code of Ethics. What should the practitioner do?

A. Proceed because it is legal
B. Refuse and escalate, citing professional ethics
C. Ignore the code
D. Ask a peer

Q17: Explanation

Correct Answer: B

Ethics is independent of legality:

- Ethics is independent of legality
- Certification holders commit to the Code
- Escalation preserves professional standards

Critical Trap

Legal is not the same as ethical.

Q18: Whistleblower Protection

Question

An employee reports fraud but is retaliated against. What governance failure is MOST visible?

- A Weak anti-retaliation controls and culture
- B Weak marketing controls
- C Weak IT procurement
- D Weak training budget

Q18: Explanation

Correct Answer: A

Retaliation kills reporting:

- Retaliation kills honest escalation
- Anonymous channels and protections are required
- Culture signals the absence of safety

Critical Trap

Silence is a governance failure.

Q19: Regulatory Ambiguity

Question

A regulator has issued guidance but not a formal rule. How should the practitioner respond?

- A Wait for a formal rule
- B Assess exposure, interpret guidance with legal, and prepare proportionate controls
- C Ignore guidance
- D Move to another jurisdiction

Q19: Explanation

Correct Answer: B

Guidance signals intent:

- Guidance signals regulatory intent
- Legal counsel interprets applicability
- Preparation reduces future risk

Critical Trap

Treat guidance as a signal, not silence.

Q20: Ethics of Automation

Question

An AI model automates decisions with material impact. What should governance require before deployment?

A. Faster deployment

B. Explainability, oversight, and a defined accountable owner

C. Fewer controls

D. No user notification

Q20: Explanation

Correct Answer: B

Accountable automation:

- Explainability supports accountability
- Human oversight catches bias and failure
- Unowned models cannot be governed

Critical Trap

Automation requires accountability, not just speed.

Q21: Third-Party Ethics

Question

A vendor follows local laws but not the organization's ethical standards. What should governance require?

- A Accept local law as the standard
- B Apply the organization's ethical standards contractually or reassess the relationship
- C Ignore the difference
- D Outsource more

Q21: Explanation

Correct Answer: B

Ethics follow the enterprise:

- Ethics are organizational, not jurisdictional
- Contracts can require compliance with internal standards
- Mismatch is a governance gap

Critical Trap

Ethical standards follow the enterprise.

Q22: Data Subject Rights

Question

A data subject requests deletion of their data. What governance principle MOST applies?

A. Availability first
B. Data subject rights must be honored per regulation and policy
C. Profit first
D. Delay as long as possible

Q22: Explanation

Correct Answer: B

Rights are obligations:

- Data rights are a regulatory obligation
- Policies must define handling
- Delay creates legal exposure

Critical Trap

Rights are obligations, not options.

Q23: Contractual Obligations

Question

A contract requires 24-hour breach notification, but policy says 72 hours. What should the practitioner do?

A. Follow policy

B. Identify the gap and recommend amending policy or contract to align

C. Ignore the contract

D. Delay notification

Q23: Explanation

Correct Answer: B

Contracts bind:

- Contracts are binding obligations
- Conflicts must be resolved in governance
- Notification timing matters legally

Critical Trap

Contractual timing overrides internal defaults.

Q24: Legal Counsel Role

Question

When should the risk practitioner involve legal counsel?

- A. Only after an incident
- B. When regulatory interpretation, contractual risk, or legal exposure is unclear
- C. Never
- D. Only at year-end

Q24: Explanation

Correct Answer: B

Engage legal early:

- Legal interprets obligations
- Timely involvement avoids missteps
- Year-end reviews are too late

Critical Trap

Engage legal early on legal questions.

Q25: Ethics Reporting

Question

The organization lacks an anonymous ethics reporting channel. What is the MAIN governance gap?

A. Too few channels for reporting wrongdoing safely
B. Too many meetings
C. Too much marketing
D. Too many tools

Q25: Explanation

Correct Answer: A

Safe channels needed:

- Safe reporting supports transparency
- Anonymous channels protect reporters
- Absence increases undetected issues

Critical Trap

Safe reporting is a governance control.

Q26: CRO Role

Question

Which is the PRIMARY responsibility of the Chief Risk Officer (CRO)?

A. Operating IT controls
B. Owning enterprise risk strategy and oversight
C. Auditing the enterprise
D. Approving budgets

Q26: Explanation

Correct Answer: B

CRO sets strategy:

- The CRO leads enterprise risk strategy
- The CRO does not operate controls
- The CRO advises and oversees

Critical Trap

The CRO sets strategy and oversees.

Q27: CISO Role

Question

A CISO reports to the CIO who also owns IT operations. What potential conflict arises?

- A. No conflict
- B. Independence is weakened; the CISO may be less able to challenge IT operations
- C. Stronger security
- D. Better governance

Q27: Explanation

Correct Answer: B

Independence matters:

- Independence is critical for security oversight
- Reporting to operations owners can mute challenges
- Some organizations place the CISO under the CEO or CRO

Critical Trap

Independence shapes honest challenge.

Q28: Data Owner Role

Question

Who is accountable for determining classification and access to customer data?

A. Data custodian
B. Data owner
C. Data user
D. System administrator

Q28: Explanation

Correct Answer: B

Owners classify:

- Data owners classify and authorize access
- Custodians implement controls
- Administrators operate systems

Critical Trap

Owners classify and authorize; custodians implement.

Q29: Data Custodian Role

Question

Who implements and maintains the technical controls protecting data?

A. Data owner
B. Data custodian
C. The board
D. The regulator

Q29: Explanation

Correct Answer: B

Custodians implement:

- Custodians implement controls
- Owners define requirements
- Boards oversee, not implement

Critical Trap

Custodians implement; owners decide.

Q30: Business Unit Accountability

Question

A business unit launches a new service without security review. Who is accountable?

A. The vendor

B. The business unit leader who owns the service

C. The IT helpdesk

D. The external auditor

Q30: Explanation

Correct Answer: B

Business leaders own business risk:

- Business leaders own business risk
- IT and security advise
- The vendor is not accountable to the enterprise

Critical Trap

Business leaders own business risk.

Q31: Steering Committee

Question

What is the PRIMARY purpose of an IT steering committee?

A. Writing code

B. Aligning IT investments and priorities with business objectives

C. Auditing IT

D. Operating infrastructure

Q31: Explanation

Correct Answer: B

Alignment purpose:

- Steering committees govern IT priorities
- Alignment ensures value
- Operational work belongs elsewhere

Critical Trap

Steering committees align IT and business.

Q32: Board Audit Committee

Question

Which activity BEST fits the board audit committee?

A. Implementing controls
B. Overseeing financial reporting, internal control, and risk assurance
C. Operating the IT service desk
D. Selecting vendors

Q32: Explanation

Correct Answer: B

Audit committees oversee:

- Audit committees oversee assurance
- They do not implement or operate
- Independence is essential

Critical Trap

Audit committees oversee, not operate.

Q33: Delegation Limits

Question

Can a board permanently delegate risk appetite to a committee?

A. Yes, fully

B. No; the board retains ultimate accountability

C. Yes, if the CEO agrees

D. Yes, if regulations allow

Q33: Explanation

Correct Answer: B

Ultimate accountability stays:

- Delegation can be operational
- Ultimate accountability remains with the board
- Appetite is board-level

Critical Trap

Ultimate accountability stays with the board.

Q34: Segregation in Governance

Question

The same executive approves risk and audits performance. What is the concern?

A. Efficiency
B. Lack of independence and potential conflict of interest
C. Cost savings
D. Better documentation

Q34: Explanation

Correct Answer: B

Independence prevents self-review:

- Independence prevents self-review
- Different parties should audit and approve
- Combining roles weakens governance

Critical Trap

Self-review weakens governance.

Q35: Governance of Third Parties

Question

Who should approve critical vendor onboarding?

A. The procurement clerk
B. The business owner, supported by risk and security review
C. Any team member
D. The vendor itself

Q35: Explanation

Correct Answer: B

Owners approve:

- Business owners accept the risk
- Risk and security advise
- Approval needs authority and context

Critical Trap

Owners approve; advisors advise.

Q36: ERM Scope

Question

Enterprise risk management should cover:

A. Only IT risks
B. Only financial risks
C. All material risks across the enterprise
D. Only compliance risks

Q36: Explanation

Correct Answer: C

ERM is enterprise-wide:

- ERM is enterprise-wide
- It aggregates and prioritizes risks
- Siloed risk management misses cross-cutting exposure

Critical Trap

ERM is enterprise-wide.

Q37: Risk Universe

Question

What is the "risk universe"?

A. All identified IT assets

B. The full set of material risks facing the enterprise

C. A list of vendors

D. A list of projects

Q37: Explanation

Correct Answer: B

The risk universe is enterprise-wide:

- The risk universe is enterprise-wide
- It includes strategic, operational, financial, compliance, and IT risks
- It is the basis for prioritization

Critical Trap

The universe is the full set of material risks.

Q38: Risk Portfolio

Question

Risk portfolio thinking means:

- A Assessing risks only individually
- B Considering the aggregate and interactions of risks together
- C Ignoring correlations
- D Ranking risks by age

Q38: Explanation

Correct Answer: B

Portfolio view:

- Portfolios capture combined exposure
- Correlations and dependencies matter
- Single-risk views miss systemic risk

Critical Trap

Portfolio view catches combined exposure.

Q39: Risk Aggregation

Question

Why is enterprise-level risk aggregation important?

- A It hides small risks
- B It reveals combined exposure that single-risk views may miss
- C It removes the need for controls
- D It replaces business judgment

Q39: Explanation

Correct Answer: B

Aggregation shows total exposure:

- Aggregation shows total exposure
- Multiple small risks can exceed appetite
- It supports informed strategy

Critical Trap

Small risks can add up to big exposure.

Q40: Risk Tolerance Statements

Question

A tolerance statement says "risk above $5M requires board approval." What is this an example of?

- A. A control
- B. A defined escalation threshold reflecting tolerance
- C. An audit finding
- D. A project plan

Q40: Explanation

Correct Answer: B

Tolerance expressed as threshold:

- Tolerance is expressed in thresholds
- Thresholds drive escalation
- Clarity improves governance

Critical Trap

Tolerance is expressed in clear thresholds.

Q41: Risk Reporting Cadence

Question

Enterprise risk reporting to the board should be:

A. Only during audits

B. On a defined cadence with escalation for material changes

C. Never

D. Annually only

Q41: Explanation

Correct Answer: B

Cadence plus escalation:

- Cadence supports oversight
- Escalation handles urgent matters
- Annual alone misses changes

Critical Trap

Steady cadence plus escalation.

Q42: Risk Culture Measurement

Question

Which is a good signal that risk culture is healthy?

- A Employees fear reporting risks
- B Employees report risks early without fear
- C No risks are ever reported
- D Only executives report

Q42: Explanation

Correct Answer: B

Early reporting = healthy culture:

- Early reporting shows trust and awareness
- Fear suppresses information
- Silence signals cultural failure

Critical Trap

Early reporting = healthy culture.

Q43: Risk Appetite Translation

Question

A board appetite statement says “avoid regulatory penalties.” How should it translate into IT risk thresholds?

- A No thresholds needed
- B Define specific compliance KRIs and thresholds that reveal regulatory risk
- C Ignore regulatory risk
- D Rely on the legal team

Q43: Explanation

Correct Answer: B

Translate intent:

- Appetite must translate to measurable indicators
- KRIs turn intent into oversight
- Reliance on one function without thresholds leaves gaps

Critical Trap

Translate intent into measurable indicators.

Q44: Risk Reporting Quality

Question

Executive risk reports should emphasize:

A. Raw technical data

B. Business impact, trends, and appetite comparison

C. Every incident

D. Vendor pricing

Q44: Explanation

Correct Answer: B

Business impact matters:

- Executives need decision-relevant data
- Trends and appetite comparison drive action
- Raw data overwhelms

Critical Trap

Business impact drives decision-making.

Q45: KRI vs KPI Reporting

Question

Which statement about KRIs and KPIs is correct?

A. They are the same
B. KRIs signal changing exposure; KPIs measure operational performance
C. KPIs predict risk
D. KRIs replace KPIs

Q45: Explanation

Correct Answer: B

KRIs signal risk; KPIs measure performance:

- KRIs are risk-focused
- KPIs measure performance toward goals
- Both are useful for different purposes

Critical Trap

KRI = risk; KPI = performance.

Q46: Culture vs Training

Question

The organization runs annual training but executives publicly dismiss risks. Which has greater impact on culture?

A. Training
B. Executive behavior
C. Policy documents
D. Vendor certifications

Q46: Explanation

Correct Answer: B

Behavior beats training:

- Culture follows leadership behavior
- Training alone cannot offset dismissal
- Behavior drives decisions

Critical Trap

Behavior beats training in shaping culture.

Q47: Blame Culture

Question

A blame culture exists. What is the MOST likely effect?

- A Fewer risks reported
- B More honest reporting
- C Stronger controls
- D Higher morale

Q47: Explanation

Correct Answer: A

Blame suppresses disclosure:

- Blame suppresses disclosure
- Early warning becomes rare
- Silence hides real risks

Critical Trap

Blame kills reporting.

Q48: Incentive Misalignment

Question

Sales bonuses reward revenue without security considerations. What should governance do?

A. Ignore the incentives
B. Align incentives with risk-aware behavior
C. Increase sales targets
D. Eliminate bonuses

Q48: Explanation

Correct Answer: B

Align incentives:

- Incentives drive behavior
- Misalignment creates unmanaged risk
- Alignment encourages balanced decisions

Critical Trap

Incentives shape risk-taking.

Q49: Awareness Program

Question

Which is the STRONGEST indicator that a security awareness program is working?

- A Training completion rates are high
- B Employees spot and report suspicious activity
- C Training is delivered
- D Posters are visible

Q49: Explanation

Correct Answer: B

Behavior indicators matter:

- Behavioral indicators matter
- Completion measures activity, not behavior
- Reporting shows real awareness

Critical Trap

Behavior beats completion rates.

Q50: Executive Sponsorship

Question

A security initiative lacks executive sponsorship. What is the likely outcome?

A. Success
B. Reduced engagement and resources
C. Immediate failure
D. Better culture

Q50: Explanation

Correct Answer: B

No sponsorship, no traction:

- Sponsorship drives resources
- Unowned initiatives fade
- Leadership visibility sustains effort

Critical Trap

No sponsorship, no traction.

Q51: Communication of Appetite

Question

Risk appetite is documented but never communicated to staff. What is the MOST likely result?

A. Alignment improves
B. Decisions ignore appetite and drift
C. Staff still follow appetite
D. Costs fall

Q51: Explanation

Correct Answer: B

Appetite must be known:

- Appetite must be known to guide choices
- Silence produces drift
- Communication aligns behavior

Critical Trap

Uncommunicated appetite is unmanaged appetite.

Q52: Risk Culture Metrics

Question

Which metric BEST supports measuring risk culture?

A. Number of training slides
B. Reported near misses and risk escalations over time
C. Vendor count
D. Budget size

Q52: Explanation

Correct Answer: B

Near misses show culture:

- Near misses reveal culture maturity
- Escalation trends indicate honesty
- Volume measures activity, not culture

Critical Trap

Culture is measured by behavior and reporting.

Q53: Leadership Walkaway

Question

Leaders ignore agreed risk decisions. What is the MOST likely culture impact?

A. Stronger compliance

B. Loss of trust and reduced commitment to risk management

C. Better alignment

D. Higher training quality

Q53: Explanation

Correct Answer: B

Inconsistency erodes trust:

- Inconsistency erodes trust
- Commitments must be honored
- Employees mirror leadership

Critical Trap

Inconsistent leadership destroys credibility.

Q54: Whistleblower Channels

Question

A strong whistleblower channel supports governance by:

A. Discouraging reporting
B. Providing a safe route to surface wrongdoing
C. Replacing audits
D. Eliminating risk

Q54: Explanation

Correct Answer: B

Safe channels surface issues:

- Safe channels surface issues early
- Anonymity reduces fear
- Channels complement other controls

Critical Trap

Safe channels surface hidden issues.

Q55: Cultural Silence

Question

Employees believe reporting will not lead to action. What is the MOST likely outcome?

- A Issues are disclosed anyway
- B Silence, and undetected risks grow
- C Better training
- D More auditors

Q55: Explanation

Correct Answer: B

No follow-through, no reporting:

- Belief that action will not follow discourages reporting
- Silence hides exposure
- Action builds trust

Critical Trap

No follow-through, no reporting.

Q56: Third-Party Accountability

Question

When a service is outsourced, accountability for the data remains with:

A. The vendor
B. The outsourcing organization
C. The regulator
D. The insurance company

Q56: Explanation

Correct Answer: B

Accountability cannot be outsourced:

- Accountability cannot be outsourced
- Vendors can be responsible operationally
- The organization remains accountable to regulators

Critical Trap

Outsourcing does not transfer accountability.

Q57: Vendor Risk Tiering

Question

Which is the BEST way to categorize vendor risk?

A. By contract value

B. By the criticality of services and data access

C. By the vendor's marketing

D. By the vendor's age

Q57: Explanation

Correct Answer: B

Criticality drives risk:

- Criticality drives risk
- Data access influences exposure
- Contract value does not reflect risk

Critical Trap

Tier vendors by criticality and access.

Q58: Fourth-Party Risk

Question

A critical vendor uses subcontractors. What is this called and why does it matter?

A. First-party risk; it does not matter

B. Fourth-party risk; visibility is reduced and risk may be higher than expected

C. Third-party risk; it is the same

D. No risk

Q58: Explanation

Correct Answer: B

Fourth-party risk adds hidden risk:

- Fourth-party risk is vendor-of-vendor
- It affects reliability and compliance
- Visibility is critical

Critical Trap

Vendor chains add hidden risk.

Q59: Vendor Exit Strategy

Question

Why should an exit plan exist before signing a critical vendor contract?

- A To shorten the contract
- B To reduce dependency and ensure data return and continuity
- C To save money
- D To avoid audits

Q59: Explanation

Correct Answer: B

Plan for exit before entering:

- Exit plans reduce lock-in and recovery risk
- Data return is a legal necessity
- Continuity depends on early planning

Critical Trap

Plan for exit before you enter.

Q60: Contractual Controls

Question

Which contract clauses MOST support governance of third-party risk?

A. Price and delivery

B. Right-to-audit, breach notification, and security obligations

C. Branding and marketing

D. Coffee vendor preference

Q60: Explanation

Correct Answer: B

Clauses that enable oversight:

- Audit rights and obligations give oversight
- Notification enables timely response
- Price does not address risk

Critical Trap

Clauses that enable oversight protect you.

Q61: Vendor Assurance

Question

A vendor provides no independent assurance. What governance response BEST fits?

A. Accept with no additional controls

B. Require alternative assurance or add compensating controls

C. Ignore it

D. Cancel the contract without assessment

Q61: Explanation

Correct Answer: B

Substitute or compensate:

- Alternative assurance can substitute
- Compensating controls reduce exposure
- Cancellation needs context

Critical Trap

Substitute or compensate, don't ignore.

Q62: Vendor Concentration

Question

All critical services depend on one provider. What should governance require?

A. More dependency

B. Concentration risk assessment and contingency plan

C. No action

D. A larger contract

Q62: Explanation

Correct Answer: B

Concentration needs strategy:

- Concentration increases impact
- Contingency plans reduce exposure
- Contracts alone do not reduce concentration

Critical Trap

Concentration needs explicit strategy.

Q63: Vendor Governance Cadence

Question

Vendor reviews occur only at contract renewal. What is the weakness?

A. Nothing
B. Reviews are too infrequent to detect drift
C. Renewal is sufficient
D. The vendor prefers renewal

Q63: Explanation

Correct Answer: B

Vendors change between renewals:

- Vendor risk changes over time
- Periodic review catches drift
- Renewal-only is too late

Critical Trap

Vendors change between renewals.

Q64: Vendor Incident Notification

Question

Which governance clause is MOST valuable for incident response?

- A Timely notification obligations with defined timelines
- B Free coffee at meetings
- C Branding rights
- D Discount clauses

Q64: Explanation

Correct Answer: A

Notice clauses save time:

- Timely notice enables response
- Defined timelines create accountability
- Notifications protect both parties

Critical Trap

Notice clauses save time and exposure.

Q65: Vendor Certification Reliance

Question

The vendor holds an ISO 27001 certificate. What should the practitioner do?

A. Stop all oversight
B. Confirm scope and recency, and continue ongoing oversight
C. Ignore the certificate
D. Assume zero risk

Q65: Explanation

Correct Answer: B

Certification is a checkpoint:

- Certifications show capability, not current performance
- Scope and recency matter
- Ongoing oversight remains necessary

Critical Trap

Certification is a checkpoint, not a guarantee.

Q66: Appetite vs Tolerance

Question

Which distinction is correct?

A. Appetite is tolerated variation; tolerance is intent

B. Appetite is the level of risk the enterprise is willing to seek or accept; tolerance is acceptable variation

C. They are the same

D. Appetite applies only to IT

Q66: Explanation

Correct Answer: B

Appetite vs tolerance:

- Appetite reflects willingness
- Tolerance reflects permitted variance
- Both are set by leadership

Critical Trap

Appetite = willingness; tolerance = variation.

Q67: Board Reporting Purpose

Question

What is the MAIN purpose of risk reporting to the board?

A. To show activity

B. To enable oversight and informed decisions

C. To compare vendors

D. To justify the IT budget

Q67: Explanation

Correct Answer: B

Reporting enables oversight:

- Oversight requires insight
- Decisions need context and consequence
- Reports enable action

Critical Trap

Reporting exists to enable oversight.

Q68: KRI Threshold Breach

Question

A KRI threshold is breached. What should governance expect?

A. No action
B. A defined escalation and response process
C. A new KRI
D. An audit

Q68: Explanation

Correct Answer: B

Breaches require responses:

- Thresholds should trigger action
- Defined processes avoid confusion
- Ignoring signals breaks trust in governance

Critical Trap

Breaches require defined responses.

Q69: Reporting Aggregation

Question

Reporting aggregates all business units into one risk score. What is the RISK of doing this?

A. Simplicity

B. Losing detail and missing concentrated risk in a specific unit

C. Reducing effort

D. Faster reporting

Q69: Explanation

Correct Answer: B

Aggregation can hide concentration:

- Aggregation can hide concentration
- Detail matters for decisions
- Summary and detail must coexist

Critical Trap

Aggregation can hide concentration.

Q70: Loss of Appetite

Question

Leaders begin accepting risks well above the stated appetite. What is the MOST likely consequence?

- A Stronger governance
- B Appetite becomes meaningless and risk-taking becomes uncontrolled
- C Reduced training
- D Higher morale

Q70: Explanation

Correct Answer: B

Unenforced appetite is fiction:

- Appetite must bind behavior
- Unbounded acceptance loses discipline
- Governance relies on consistent limits

Critical Trap

Unenforced appetite is fiction.

Q71: Assurance Independence

Question

Which report is MOST credible to the board?

- A. A self-assessment
- B. An independent assurance report
- C. A vendor's marketing summary
- D. An informal email

Q71: Explanation

Correct Answer: B

Independence supports credibility:

- Independence supports credibility
- Self-assessment can be biased
- Marketing is not assurance

Critical Trap

Independent assurance carries weight.

Q72: Reporting Frequency

Question

Which reporting cadence is MOST appropriate for critical risks?

A. Every five years
B. Defined cadence with escalation for material change
C. Never
D. Annually only

Q72: Explanation

Correct Answer: B

Cadence plus escalation:

- Cadence maintains oversight
- Escalation handles urgent changes
- Long gaps miss movement

Critical Trap

Regular cadence plus escalation.

Q73: Audience Tailoring

Question

A board report uses the same technical detail as an operations report. What is the MAIN issue?

A. Nothing
B. Mismatch between audience and detail reduces usefulness
C. Too many auditors
D. Too few incidents

Q73: Explanation

Correct Answer: B

Tailor to the audience:

- Boards need decision-level content
- Operations need technical detail
- Tailoring improves use

Critical Trap

Tailor the message to the audience.

Q74: Risk Statement Quality

Question

Which risk statement is BEST for reporting?

A. Servers might break

B. Unpatched customer-facing servers may allow data breaches causing regulatory fines and lost trust

C. Patch status is 87%

D. There are 47 servers

Q74: Explanation

Correct Answer: B

Risk statements link cause, event, consequence:

- Good risk statements link cause, event, and consequence
- Consequences drive decisions
- Raw counts do not

Critical Trap

Risk statements link cause, event, consequence.

Q75: Reporting Bias

Question

Reports consistently minimize negative news. What is the MAIN impact?

A. Stronger governance
B. Loss of trust and poor decisions
C. Faster remediation
D. Higher KPIs

Q75: Explanation

Correct Answer: B

Bias undermines oversight:

- Bias undermines oversight
- Leaders cannot act on distorted data
- Trust erodes

Critical Trap

Minimized news leads to misinformed decisions.

Q76: BCP Ownership

Question

Who should own the business continuity plan?

A. IT operations
B. Business leaders, with IT support
C. Vendors
D. The helpdesk

Q76: Explanation

Correct Answer: B

Business owns continuity:

- Business owns continuity priorities
- IT supports with technology recovery
- Ownership drives priorities

Critical Trap

Business owns continuity; IT enables it.

Q77: BCP Testing

Question

A BCP exists but has never been tested. What is governance's BEST action?

A. Assume it works
B. Require regular testing and reporting of results
C. Ignore it
D. Postpone indefinitely

Q77: Explanation

Correct Answer: B

Untested plans are unproven:

- Untested plans are unreliable
- Testing reveals gaps
- Reporting supports oversight

Critical Trap

Untested plans are unproven.

Q78: Continuity Scope

Question

A BCP covers only IT systems. What is the MOST likely gap?

- A Too much coverage
- B Business process continuity, people, and facilities are missing
- C Too many tests
- D Overfunded

Q78: Explanation

Correct Answer: B

Continuity is business, not just IT:

- Continuity is broader than IT
- People and facilities matter
- Process continuity is the goal

Critical Trap

Continuity is business, not just IT.

Q79: Crisis Communication

Question

Who should lead crisis communications during a major incident?

A. Any engineer
B. A designated, trained role with governance authority
C. The vendor
D. The insurer

Q79: Explanation

Correct Answer: B

Crisis communications needs governance:

- Communications needs trained ownership
- Authority avoids conflicting messages
- Vendors and insurers support, not lead

Critical Trap

Crisis communications needs governance.

Q80: Plan Maintenance

Question

The BCP was updated three years ago but operations have changed significantly. What is the governance risk?

A. None

B. The plan may not reflect the current environment and may fail when needed

C. The plan is too new

D. Too much testing

Q80: Explanation

Correct Answer: B

Stale plans fail when needed:

- Plans must reflect current operations
- Changes invalidate assumptions
- Regular reviews maintain relevance

Critical Trap

Stale plans fail when needed.

Q81: IT Investment Approval

Question

Which principle governs approval of major IT investments?

- A All investments approved by IT only
- B Investments are approved by appropriate authority and aligned with business objectives
- C Investments are approved by the vendor
- D Only by the audit committee

Q81: Explanation

Correct Answer: B

Investments align with objectives:

- Investments need authority and alignment
- Business objectives guide value
- Vendor approval is not governance

Critical Trap

Investments align with objectives and authority.

Q82: Resource Optimization

Question

Resource optimization in IT governance means:

A. Reducing cost at all costs
B. Balancing cost, risk, and value to meet business objectives
C. Maximizing headcount
D. Buying the newest tools

Q82: Explanation

Correct Answer: B

Balance cost, risk, and value:

- Optimization is balanced
- Value and risk matter alongside cost
- Cost reduction alone creates risk

Critical Trap

Balance cost, risk, and value.

Q83: Performance Measurement

Question

IT performance should be measured against:

A. Peer opinions
B. Business objectives and agreed service levels
C. Vendor promises
D. Employee satisfaction alone

Q83: Explanation

Correct Answer: B

Measure against business goals:

- Performance aligns with business goals
- Service levels define expectations
- Opinions and promises are not measures

Critical Trap

Measure IT against business goals.

Q84: Value Delivery

Question

Value delivery from IT is demonstrated when:

A. Projects finish on budget alone
B. Benefits are realized and aligned with strategy
C. Technology is modern
D. Licenses are cheap

Q84: Explanation

Correct Answer: B

Value = realized benefits:

- Value is realized benefits
- Strategy alignment matters
- Budget and modernity do not equal value

Critical Trap

Value = realized benefits aligned with strategy.

Q85: Governance of Change

Question

Which control best supports governance over significant IT changes?

A. Every change is approved

B. A defined change process with appropriate authority levels

C. Only emergency changes are governed

D. Vendors approve all changes

Q85: Explanation

Correct Answer: B

Authority-based change control:

- Authority-based change control fits risk
- Excessive approvals slow operations
- Vendors must not approve internal changes

Critical Trap

Change governance is authority-based.

Q86: Board Knowledge Gap

Question

The board has no IT expertise. What is the BEST governance response?

A. Ignore IT risk

B. Establish training, independent advice, or a technology committee to support oversight

C. Delegate all IT to the CIO

D. Cancel IT projects

Q86: Explanation

Correct Answer: B

Capability for oversight:

- Oversight requires capability
- Advisory structures support boards
- Deferring IT entirely abdicates oversight

Critical Trap

Boards need capability to oversee IT.

Q87: Board Independence

Question

The board majority is composed of executives from the company. What is the concern?

A. Stronger oversight

B. Weakened independence and potential conflict of interest

C. Faster decisions

D. Lower cost

Q87: Explanation

Correct Answer: B

Independence protects oversight:

- Independence supports oversight
- Executive-heavy boards may lack challenge
- Governance depends on independence

Critical Trap

Independence protects oversight.

Q88: Executive Removal

Question

An executive was dismissed for reporting a serious risk. What is the MOST likely culture outcome?

A. Stronger risk management
B. Silence and suppressed risk reporting
C. Better training
D. Increased audits

Q88: Explanation

Correct Answer: B

Punishment silences:

- Fear drives silence
- Retaliation damages trust
- Culture erodes

Critical Trap

Punishing risk reporting silences the organization.

Q89: Governance of Outages

Question

Repeated outages are tolerated without change. What governance principle is MOST relevant?

A. Ignoring trends
B. Accountability for performance and corrective action
C. Increasing budgets
D. Marketing better

Q89: Explanation

Correct Answer: B

Repeated failures need response:

- Governance requires performance ownership
- Repeated failures signal gaps
- Corrective action is expected

Critical Trap

Repeated failures need governance response.

Q90: Mandate Clarity

Question

A regulatory mandate conflicts with a business objective. What is the BEST governance action?

- A. Ignore the regulation
- B. Identify the conflict and escalate to leadership for resolution
- C. Follow the business
- D. Delay indefinitely

Q90: Explanation

Correct Answer: B

Conflicts go to leadership:

- Conflicts require leadership decisions
- Legal obligations usually constrain business choices
- Escalation is the right path

Critical Trap

Conflicts go to leadership for resolution.

Q91: Reporting Lines

Question

The risk function reports directly to the CRO who reports to the CEO. What is the governance advantage?

A. Less independence

B. Stronger independence and visibility of risk

C. Lower cost

D. Faster operations

Q91: Explanation

Correct Answer: B

Direct lines strengthen independence:

- Direct lines improve visibility
- Independence supports honesty
- Cost and speed are not the point

Critical Trap

Direct lines strengthen independence.

Q92: Committee Composition

Question

A risk committee lacks legal and finance members. What governance risk is MOST likely?

A. Faster decisions
B. Blind spots in legal and financial exposure
C. Better technology focus
D. Lower costs

Q92: Explanation

Correct Answer: B

Missing voices mean missing risks:

- Cross-functional perspectives catch blind spots
- Legal and finance affect risk materiality
- One-sided committees under-represent risk

Critical Trap

Missing voices mean missing risks.

Q93: Governance of Emerging Tech

Question

A new technology is rapidly adopted across business units. What governance is MOST needed?

A. Slower adoption

B. A defined framework for assessment, ownership, and oversight

C. Immediate shutdown

D. No governance

Q93: Explanation

Correct Answer: B

Adoption needs a framework:

- Frameworks balance adoption and risk
- Ownership ensures accountability
- Shutdown may harm the business

Critical Trap

Adoption needs a governance framework.

Q94: Decision Rights

Question

Which document best clarifies who makes decisions?

A. The vendor contract
B. A RACI chart or decision rights matrix
C. The audit report
D. A marketing plan

Q94: Explanation

Correct Answer: B

Decision rights belong in RACI:

- Decision rights clarify authority
- RACI assigns roles
- Other documents do not assign decision authority

Critical Trap

Decision rights belong in RACI or matrices.

Q95: Performance Escalation

Question

Business unit performance repeatedly misses risk commitments. What is the BEST governance action?

A. Ignore the misses

B. Escalate and require corrective action with accountability

C. Raise budgets

D. Cancel training

Q95: Explanation

Correct Answer: B

Missed commitments need escalation:

- Escalation addresses accountability
- Corrective action follows
- Ignoring normalizes failure

Critical Trap

Missed commitments need escalation.

Q96: Board Risk Reporting

Question

Which content is MOST valuable in a board risk report?

A. Detailed technical findings

B. Key exposures, appetite comparison, and recommended actions

C. Vendor contract details

D. Marketing performance

Q96: Explanation

Correct Answer: B

Boards need exposures and actions:

- Boards need exposures and recommendations
- Appetite comparison guides oversight
- Technical and commercial details overwhelm

Critical Trap

Boards need exposures and actions.

Q97: Risk Acceptance Formality

Question

A business owner accepts a large risk without formal documentation. What governance gap is MOST likely?

A. Missing documentation and accountability
B. Too many documents
C. Too many auditors
D. Too little technology

Q97: Explanation

Correct Answer: A

Formal acceptance is governance:

- Documentation creates accountability
- Informal acceptance is indefensible
- Governance requires traceability

Critical Trap

Formal acceptance is governance.

Q98: Conflict of Interest

Question

A risk committee member owns shares in a vendor under review. What should happen?

- A Proceed without disclosure
- B Disclose and recuse from related decisions
- C Vote on the vendor
- D Ignore the conflict

Q98: Explanation

Correct Answer: B

Disclose and recuse:

- Conflicts must be disclosed
- Recusal protects integrity
- Silence damages trust

Critical Trap

Disclose conflicts and recuse.

Q99: Executive Reporting

Question

An executive proposes reducing the risk budget without analysis. What is the BEST governance response?

A. Approve immediately
B. Require risk impact analysis and a formal decision
C. Delay indefinitely
D. Ignore the proposal

Q99: Explanation

Correct Answer: B

Budget cuts need risk analysis:

- Budget cuts affect risk exposure
- Analysis supports informed decisions
- Formal decision records accountability

Critical Trap

Budget cuts need risk analysis.

Q100: Ultimate Accountability

Question

Ultimate accountability for enterprise risk rests with:

A. The risk practitioner
B. The CISO
C. The board of directors
D. The vendor

Q100: Explanation

Correct Answer: C

Ultimate accountability sits with the board:

- Boards are ultimately accountable to stakeholders
- Management executes within direction
- Practitioners and CISOs advise and operate

Critical Trap

Ultimate accountability sits with the board.

Exam Mindset Summary

Remember

- **Governance** directs; **management** executes
- **Accountability** cannot be delegated or outsourced
- **Appetite** is board-owned; **tolerance** is permitted variation
- **Three lines:** operate (1st), oversee (2nd), audit (3rd)
- **Policy** states intent; **standards** specify requirements
- **Culture** follows leadership behavior, not slogans

Thank You

Good Luck on Your CRISC Exam!